

Séance 4

Attaque Man-In-The-Middle (MITM) d'un service HTTP

+ Mise en place de contre-mesures

Ce TP a pour but de simuler une attaque de l'homme du milieu sur un service HTTP afin de démontrer le besoin de chiffrement et l'utilité d'utiliser le protocole HTTPS. Son objectif est l'analyse de failles liées à l'usage de certains protocoles réseaux afin de proposer une amélioration de la sécurité informatique d'un système d'information.

Note 1 : Avant de partir vous devrez m'envoyer, à l'adresse suivante (romain.dulout@u-bordeaux.fr), un court rapport répondant à l'ensemble des questions posées en précisant le numéro de la séance.

Note 2 : Lorsque des commandes nécessitant des privilèges administrateurs seront utilisées, il sera nécessaire d'utiliser la commande *sudo* sous Debian GNU/Linux et *doas* sous OpenBSD.

Note 3 : Pour mettre ServMutillidae en FR : *sudo loadkeys fr*

Note 4 : Sur les dernières versions de VirtualBox, il peut être nécessaire de réaliser une étape de configuration pour que l'ensemble des adresses IP puissent être utilisées (et vboxnet1 créé). L'étape en question consiste à créer un fichier *"/etc/vbox/networks.conf"* contenant *"* 0.0.0.0/0 ::/0"* et à relancer VirtualBox. Pour en savoir plus : https://www.virtualbox.org/manual/ch06.html#network_hostonly

A. Mise en place de l'environnement

- Récupérez le fichier lab2_bloc3.ova et importez-le sur le logiciel VirtualBox (Fichier>Importer un appareil virtuel).
- Modifiez la politique d'adresse MAC : Générer de nouvelles adresses MAC pour toutes les interfaces réseaux
- Cliquez sur Importer

Une fois les différentes machines virtuelles importées, il faut s'assurer que les deux cartes réseaux virtuelles sont bien présentes dans le gestionnaire de réseau hôte.

- **vboxnet0** ou VirtualBox Host-Only Ethernet Adapter (suivi éventuellement d'un # et numéro si des cartes virtuelles ont déjà été créées auparavant) sous Windows avec comme adresse IP **192.168.56.1/24**. Décochez l'activation du serveur DHCP.
- **vboxnet1** ou VirtualBox Host-Only Ethernet Adapter sous Windows avec comme adresse IP **172.16.10.1/24**. Décochez l'activation du serveur DHCP. Pour ceux qui ne peuvent pas changer l'IP en 172.16.10.1/24 faire :
 - `sudo mkdir -p /etc/vbox`
 - `sudo nano /etc/vbox/networks.conf` (et y mettre `* 0.0.0.0/0 ::/0`)
 - `sudo systemctl restart vboxdrv 2>/dev/null || sudo /sbin/vboxconfig`

Enfin, il s'agit de lier les machines virtuelles aux bons réseaux :

- DebDNSsrv lab2 - Adaptateur 1 : vboxnet1
- ServMetasploit lab2 - Adaptateur 1 : vboxnet1
- DebClient lab2 - Adaptateur 1 : vboxnet0
- KaliAttaquant lab2 - Adaptateur 1 : vboxnet0
- RouteurOpenBSD lab2 - Adapt 1 : NAT ; Adapt 2 : vboxnet0 ; Adapt 3 : vboxnet1

Les mots de passe des différentes machines sont les suivants :

- Pour le serveur MetaSploit : msfadmin msfadmin
- Pour les autres : etusio Fghijkl1234*

B. Attaque MITM d'un service HTTP

Lancez les 5 machines du laboratoire 2 (il vous est possible de ne pas démarrer le serveur DNS ici - sauf si vous souhaitez effectuer dans le Client des recherches Internet).

a. Découverte des hôtes et services présents sur un réseau local

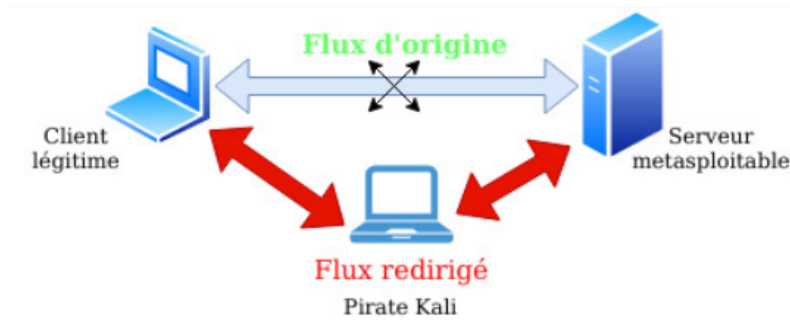
Q1. Quelles commandes utilisées durant les séances précédentes peuvent permettre à l'attaquant de visualiser la liste des machines présentes dans les différents sous-réseaux ainsi que les services en fonctionnement sur chacune d'elles ? Fournissez, sous forme d'une liste les différentes machines présentes dans chacun des sous-réseaux ainsi que les services en fonctionnement sur chacune d'elles.

Q2. Qu'est ce que le serveur Metasploitable mis en oeuvre dans ce laboratoire ? Quel est son objectif ? Pourquoi possède-t-il un nombre important de ports ouverts ?
(Source : <https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/>)

Dans le cadre de la séance du jour, nous allons cibler le serveur HTTP présent sur le serveur Metasploitable : celui-ci accueille en effet un site Web Mutillidae conçu pour identifier et tester les failles de sécurité.

Ce que nous allons chercher à mettre en évidence ici est le risque lié à l'utilisation d'une communication HTTP non sécurisée : le pirate Kali va pour cela chercher à empoisonner le cache ARP du client légitime et récupérer le mot de passe de son compte Mutillidae transmis en clair via la connexion non sécurisée HTTP.

Q3. D'après les mises en pratiques précédentes, que va permettre de faire ici l'empoisonnement du cache ARP ?



b. Simulation d'une attaque de l'homme du milieu entre le client et le serveur Web

Une personne malveillante s'est donc introduite sur le réseau dans le but de récupérer entre autres des informations confidentielles dont des noms d'utilisateurs et mots de passe disposant de privilèges. Après avoir analysé l'architecture réseau et découvert l'existence d'un serveur Web, elle décide de réaliser une attaque Man in the Middle (MITM) afin d'obtenir un accès sur ce dernier.

Ici, nous voulons récupérer tout le trafic entre le client (192.168.56.11) et le serveur (172.16.10.5). Mais les adresses MAC qui doivent être falsifiées sont celles du client légitime et du routeur (et non du serveur qui est sur un réseau logique distant) car, pour atteindre le serveur, le client passe obligatoirement par la passerelle.

Les messages ARP piratés n'iront pas au-delà des limites du réseau logique local, l'attaque doit donc être lancée à partir d'un appareil connecté au réseau logique local. Il n'est pas impossible pour quelqu'un d'externe de lancer une attaque sur l'ARP, mais il devra d'abord compromettre à distance un système local via d'autres moyens. Une personne interne, en revanche, aura seulement besoin d'un accès au réseau et de quelques outils facilement disponibles.

Sur Kali, il est possible d'utiliser les outils Ettercap ou arpspoof pour réaliser l'empoisonnement du cache ARP. Nous avons utilisé Ettercap dans le TP MITM SSH, nous utiliserons arpspoof dans celui-ci.

i. Préalables - Configuration de la machine Kali du pirate qui doit jouer le rôle de routeur

- Activez le routage sur cette machine. Pour cela, ouvrir le fichier `/etc/sysctl.conf`, enlever le commentaire devant la ligne suivante et sauvegarder le fichier :
`net.ipv4.ip_forward=1`
- Il faut ensuite exécuter la commande suivante pour recharger les paramètres système : `sudo sysctl -p`

Q4. Avant de réaliser l'attaque, 1) consultez le cache ARP de la machine cliente légitime et relevez l'@ Mac de la passerelle, 2) consultez le cache ARP de la passerelle (arp -a) et relevez l'@ MAC de la machine cliente (pour avoir des informations dans le cache arp, vous devrez peut-être au préalable lancer un ping sur la machine cliente) et 3) relevez l'adresse IP et l'adresse MAC du pirate.

Note : Sur la machine du client légitime la commande "ip n s" peut être utilisée.

ii. Modification de la configuration du site mutillidae sur le serveur Metasploit

- Ouvrez le fichier config.inc dans /var/www/mutillidae (sudo nano /var/www/mutillidae/config.inc) et modifiez le contenu de la variable dbname par la valeur suivante : \$dbname = 'owasp10' (ceci indique le type de scénario que nous souhaitons mettre en oeuvre sur le serveur).
- Rechargez apache2 : `sudo /etc/init.d/apache2 reload`.

Il s'agit d'une très vieille distribution, le démarrage des services étaient opérés par le démon init system V).

- Depuis le Client, créez un compte sur le site : <http://172.16.10.5/mutillidae/> ou (si la VM abritant le serveur DNS est lancé) <http://srvm.local.sio.fr/mutillidae>. **Attention, ne pas encore faire de login attendre la suite du TP.**

-> Empoisonnement du cache ARP via arpspoof

L'étape suivante consiste à réaliser l'empoisonnement ARP. Pour rappel, on va envoyer des paquets de façon constante car si une communication est effectuée entre le serveur et le client, ce dernier va à nouveau mettre à jour sa table ARP et cette fois-ci avec les informations correctes. Il faut donc remettre continuellement à jour la table ARP du client et de la passerelle pour qu'elles restent falsifiées.

Pour cela, suivre les étapes suivantes depuis la machine Kali :

- Ouvrez un premier terminal puis saisissez la commande suivante :
 - `sudo arpspoof -t @ip-client-victime @ip-passerelle`

On peut traduire cette ligne de commande par « fait moi passer pour l'adresse IP de la passerelle auprès du client ». Cette commande redirige le trafic entre l'IP du client victime et la passerelle vers la machine pirate (qui a lancé la commande).

- Ouvrez un second terminal puis saisissez la commande suivante :
 - `sudo arpspoof -t @ip-passerelle @ip-client-victime`

On peut traduire cette ligne de commande de la part du pirate par « fait moi passer pour l'adresse IP du client auprès de la passerelle ». Cette commande redirige le trafic entre la passerelle et l'IP du client victime vers la machine pirate (qui a lancé la commande).

Q5. Consultez à nouveau le cache ARP de la machine cliente victime. Que remarquez-vous ? De même, au niveau du routeur victime, que remarquez-vous?

Note : Pour ne pas ouvrir deux terminaux et pour récupérer ensuite la main sur chaque terminal, il est possible d'envoyer le résultat de la commande vers « /dev/null » (après avoir ouvert une « console administrateur » avec la commande « sudo su ». sudo arpspoof -t @ip-client-victime @ip-passerelle > /dev/null 2>&1

Ne pas oublier d'arrêter les processus ensuite via la commande « Kill num_processus ».

iii. Capture et inspection de trames

Le pirate lance maintenant une capture de trame et attend que le client légitime s'authentifie sur l'application Mutillidae de la machine Metasploitable en HTTP pour capturer le mot de passe saisi puisque ce dernier circule en clair.

- Depuis la machine kali, ouvrez le logiciel Wireshark puis configurez une écoute sur le protocole HTTP.
- Depuis la machine cliente victime, connectez-vous au site Mutillidae avec le compte créé précédemment.

Q6. Le pirate peut-il lire le mot de passe saisi par la victime ? Si oui, expliquez pourquoi.

Note générale : Les organisations doivent nécessairement prendre en compte la confidentialité des échanges sur un site comportant une page d'authentification. L'article 32 du RGPD porte sur l'obligation pour une organisation de mettre en œuvre des solutions sécurisées : « Compte tenu de l'état des connaissances, des coûts de mise en œuvre et de la nature, de la portée, du contexte et des finalités du traitement ainsi que des risques, dont le degré de probabilité et de gravité varie, pour les droits et libertés des personnes physiques, le responsable du traitement et le sous-traitant mettent en œuvre les mesures techniques et organisationnelles appropriées afin de garantir un niveau de sécurité adapté au risque, y compris entre autres, selon les besoins ». Plus loin, cet article fait référence au chiffrement.

C. Mise en place de contre-mesures

a. Le chiffrement HTTPS

L'objectif est ici de faire évoluer le site Mutillidae en HTTPS afin d'instaurer une connexion chiffrée et sécurisée entre le serveur et les terminaux. Pour cela, il est nécessaire de

configurer un virtualhost sur l'application Mutillidae en suivant les étapes suivantes depuis la machine Metasploitable.

Nous utiliserons le certificat par défaut fourni par Apache. En production, il sera nécessaire d'obtenir un certificat signé par une autorité de certification "publique".

Q7. Qu'est ce qu'une autorité de certification publique ? Quelles sont les principales autorités de certification (donnez des noms) ? Quelle est la différence entre un certificat et une clé publique ?

(Sources utiles :

<https://www.ssl.com/fr/article/qu%27est-ce-qu%27une-autorit%C3%A9-de-certification-ca/>, <https://alternativeto.net/software/ssl-com/>)

Pour mettre en place le certificat fourni par défaut par apache suivent les étapes suivantes :

- Sur le serveur, activez le module ssl : `sudo a2enmod ssl`
- Créez dans le répertoire `/etc/apache2/sites-available` le fichier `default-ssl` en y mettant le contenu suivant :

```
-----
<ifModule mod_ssl.c>
    <VirtualHost 172.16.10.5:443>
        ServerName 172.16.10.5:443
        DocumentRoot /var/www/
        SSLEngine On
        SSLCertificateFile /etc/ssl/certs/ssl-cert-snakeoil.pem
        SSLCertificateKeyFile /etc/ssl/private/ssl-cert-snakeoil.key
        ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/
        <Directory "/usr/lib/cgi-bin">
            AllowOverride None
            Options +ExecCGI -MultiViews +SymLinksIfOwnerMatch
            Order allow,deny
            Allow from all
        </Directory>
    </VirtualHost>
</ifModule>
-----
```

- Activez le VirtualHost : `sudo a2ensite default-ssl`

Q8. Que permet de faire la commande `a2ensite` ? Que semble contenir le fichier `default SSL` ?

(Source : <https://manpages.ubuntu.com/manpages/trusty/man8/a2dissite.8.html>)

- Ouvrez le fichier `htaccess` situé à la racine de l'application de Mutillidae (`/var/www/mutillidae/.htaccess`) et mettez en commentaire les trois lignes commençant par `php_flag` (la commande `php_flag` utilisée pour activer ou désactiver une option n'est pas reconnue dans ce contexte) en ajoutant le caractère `#` devant :

```
## The following section disables PHP magic quoting feature.
## Turning these on will cause issues with Mutillidae.
## Note: Turning these on should NEVER be relied on as a method for securing ag$
## As of PHP 6 these options will be removed for exactley that reason.

## Donated by Kenny Kurtz
#php_flag magic_quotes_gpc off
#php_flag magic_quotes_sybase off
#php_flag magic_quotes_runtime off
```

- Redémarrez apache 2 : `sudo /etc/init.d/apache2 restart`

Depuis la machine client légitime

- Connectez-vous au site Mutillidae en utilisant le protocole HTTPS. Pour cela, vous aurez besoin d'activer TLS 1.0 sur le navigateur Firefox.
- Une fois que c'est réalisé, vous devriez avoir un message d'avertissement qui s'affiche. Vous disposez d'informations complémentaires en déroulant « Information technique ». Le cadenas précédant l'URL montre effectivement un point d'exclamation. Vous pouvez visualisez les détails du certificat en cliquant sur voir/afficher le certificat.

Selon la CNIL (<https://www.cnil.fr/fr/securite-chiffrer-garantir-lintegrite-ou-signer>), lors de la réception d'un certificat électronique, Il est essentiel de vérifier que le certificat contient une indication d'usage conforme à ce qui est attendu, qu'il est valide et non révoqué, et qu'il possède une chaîne de certification correcte à tous les niveaux ».

Q9. Quel est le rôle du certificat côté serveur ?

Q10. Visualisez les détails du certificat et expliquez chacune des raisons invoquées pour afficher que la connexion n'est pas sécurisée.

- Acceptez le risque et continuez quand même (chose à ne pas faire, bien évidemment sur un vrai site en ligne)
- Reproduisez l'attaque.

Q11. Peut-on encore capturer le mot de passe en clair ? Votre réponse doit être démontrée via une analyse de trames.

Vous pouvez vous servir des étapes suivantes

- Filtrez sur `tcp.port == 443` ;
- Repérez la trame « hello » du protocole

```
34 12.224299152 172.16.10.5 192.168.56.11 TLSv1 1011 Server Hello, Certificate, Server Hello Done
```

- Activez le menu « Analyse / Suivre / Flux TCP »

b. Mesures pour détecter l'empoisonnement du cache ARP

Q12. En configurant un site en HTTPS, l'empoisonnement de cache ARP est-il toujours possible ?

Q13. Expliquez pourquoi il peut être important de surveiller les caches ARP (notamment celui du routeur).

L'empoisonnement ARP utilisé ici n'est possible que grâce à l'émission de messages non sollicités à tout le réseau, qu'on appelle « gratuitous ARP » qui a, tout de même, l'inconvénient de générer beaucoup d'activité sur le réseau.

Des outils permettent de contrôler les modifications du cache ARP afin de vérifier les modifications suspectes. On peut citer l'exemple de l'outil arpwatch qui surveille le réseau en continu et peuvent alerter un admin si des signes d'empoisonnement du cache ARP sont détectés. Toutefois, il est nécessaire de faire attention aux faux positifs qui peuvent créer beaucoup d'alertes indésirables.

Ces outils de surveillance seront configurés dans une prochaine activité.

c. Mesures pour éviter l'empoisonnement du cache ARP

Q14. Citez deux autres mesures pouvant être mises en œuvre pour éviter l'empoisonnement du cache ARP.

(Source : <https://www.varonis.com/blog/arp-poisoning>)

Q15. Qu'est ce que HTTPS Spoofing ? Comment peut-il être mis en place ?

(Source

possible:

<https://doubleoctopus.com/security-wiki/threats-and-tools/https-spoofing/>)